FilsPay Handover

Team LGTM · audit, fix and finish a Bahrain card-payments platform

109
findings confirmed

85
fixed, test-first

22
refund gaps closed

Team LGTM

1

[Member 1]

[What they owned]

2

[Member 2]

[What they owned]

3

[Member 3]

[What they owned]

Plus Claude Code: Opus for fixes, Haiku for failing tests, Sonnet as reviewer

Root cause: the rules lived on paper, not in the code

Integer fils, unique payouts and tenant checks were written in ADRs and postmortems, but nothing in the code or the database enforced them.

1

Money maths drifted

TS and Go rewrote fils logic with floats, cents and int32

2

"Fixed" races weren't

Postmortems listed unique indexes and locks that never existed

3

Checks on the route, not the query

Any id from another merchant worked

4

Even the AI rules were planted

CLAUDE.md said cents, UTC, "don't fix refunds"

Key findings, ranked by impact

1	**Money left twice**	Two refunds of 6,000 on a 10,000 capture both succeeded; a payment link charged two buyers	F3 · R1
2	**Login skipped the OTP**	The pre-OTP cookie worked on every route, reproduced on the running API	S1 · S2
3	**Fils lost or invented**	CSV import booked 4.75 BD as 0.475 BD; volume counter wrapped and switched off the fee tier	M1 · M6
4	**Refunds never worked**	Route answered 501 and every insert failed: 22 gaps behind "just wire it"	F1–F22

Fixes and proof: a failing test before every fix

Confirm in code → **Failing test** → Smallest fix → Reviewer agent → One commit

Fix	Before	After
S1 pending session	Reaches /auth/me	**Refused**
S4 expired link, old submittedAt	200, charged	**410**
M1 CSV "4.75" BD	475 fils	**4,750 fils**
F8 capture 10,000, refund 4,000	Paid 9,750	**Paid 5,850**
Test suite baseline	16 failing	**0 of those failing**

88 new fix test files

12 new migrations

1 commit per bug

Every entry: symptom, cause, fix, test, data effect in fix-docs/FIXLOG.md

Live demo: a partial and a full refund, end to end

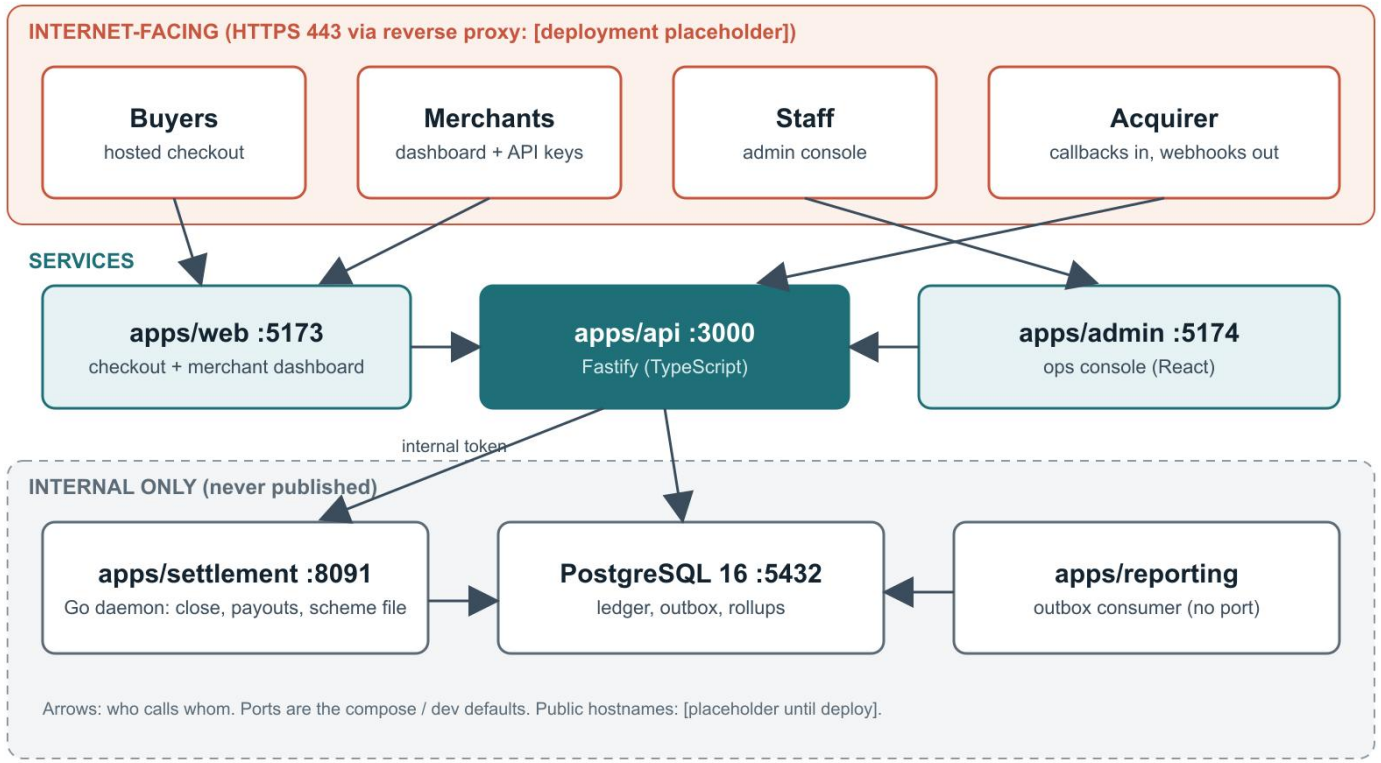
Capture	Partial refund	Full refund	Dashboard	Settlement report
10.000 BD	3.000 BD	remaining 7.000 BD	refunded, 10.000 back	payout reduced, gap 0

[Screenshot: refund drawer on the transaction]

[Screenshot: dashboard after full refund]

[Screenshot: settlement / reconciliation report]

Under load



Already fixed for load: streamed CSV export (X3). Known: missing ledger indexes (P2), no rate limiting (S16, S17).

Simulated users

Estimated	Measured
[ ]	[ ]

Bottleneck: [measured]

Overload: [proxy limits / 429 / 503]

Recovery: [what happened after]

How we used AI

Claude Code with a custom fix-and-build skill, cheap test-writer and reviewer agents, and shared memory kept in the repo.

Floorplan	Audit	Haiku	Opus	Sonnet	Git
map of the code	S, R, M, T, X, D	writes failing test	smallest fix	reviews for breakage	branch, squash, push

When the AI was wrong

Claude planned to delete **POST /v1/refunds** and keep only the dashboard's merchant-scoped route, as the audit suggested.

We stopped it: merchants already integrate on that endpoint, so removing it would break them.

Now both addresses run one handler, covered by 43 test cases, and we had it re-check every earlier fix for other integration breaks.

Decisions and open risks

Chose not to change or run

- Kept ADR-0004: rejected the audit's M9 shortcut and fixed the settled-data path
- Never ran scripts/ one-offs against data
- Didn't overwrite payout estimates or past ledger entries without Finance (M19, M14, X14)
- Smallest fix first; the bigger fix is recorded per bug

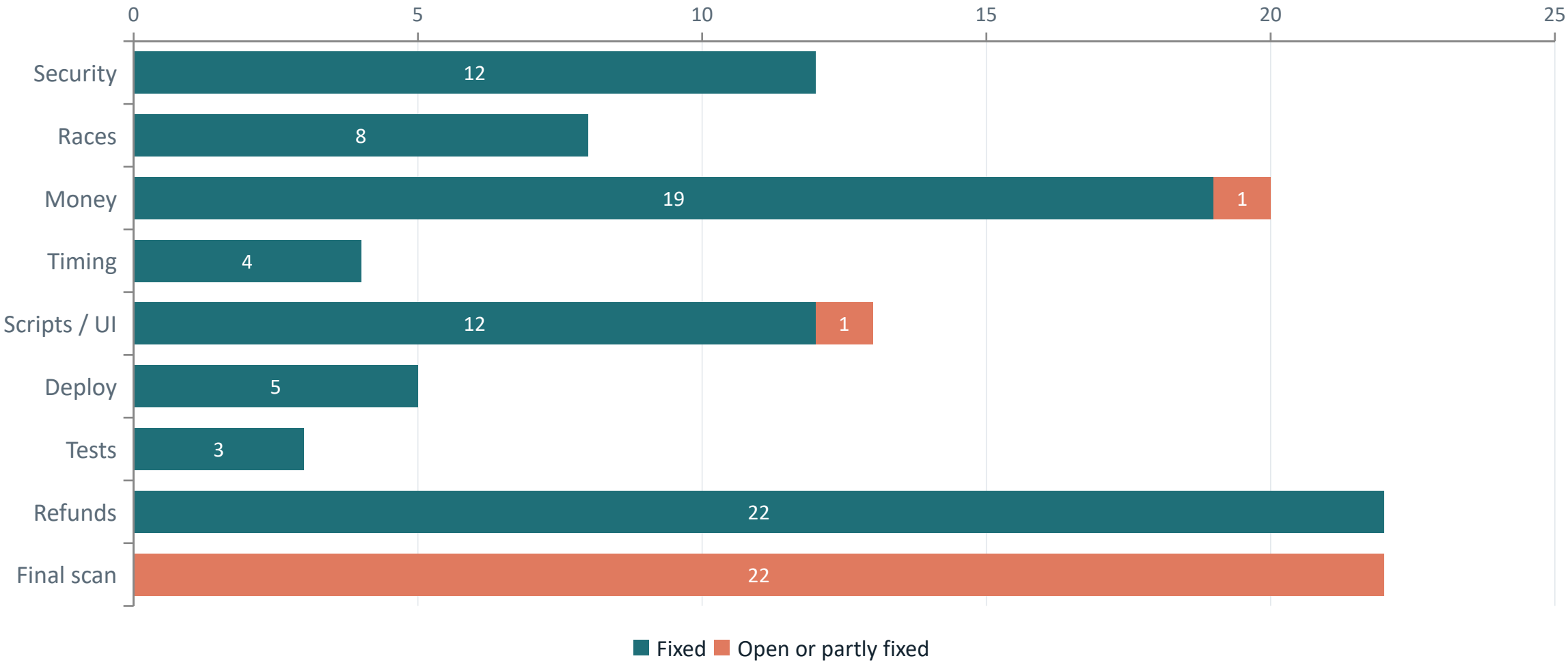
Still open

- S13 cross-merchant read, S14 SSRF, S15 dev-mode compose: fix before real traffic
- Rotate the leaked acquirer secret (S11)
- March sweep production postings (X14)
- 19 more scan items, all recorded with fixes
- [Deploy / load-test status]

Appendix

Not presented. Full detail in LGTM_FilsPay_Submission.pdf and fix-docs/FIXLOG.md

Findings by class



Proof: tests, migrations, end-to-end refund

Baseline: 16 tests failing before any fix

- 11 refund tests: every insert failed (F14)
- 1 webhook backoff test: exact assert on random jitter (Q1)
- 4 reporting tests: polluted shared DB, consumer stalled (Q2, X6)
- End-to-end refund test: ledger balances, full fee reversed, signed webhooks, reconciliation gap 0

[Final test output summary]

12 new migrations (0073–0084)

BIGINT money columns (M5, M6) · unique indexes against duplicates (R2, R3, R5) · reporting dead letters (X6) · ADR-0005 renumbering (D1) · integer scheme export (M16) · capture marker (R6) · refund columns, view and pending rows (F9, F15, F22)

[Load test graphs]